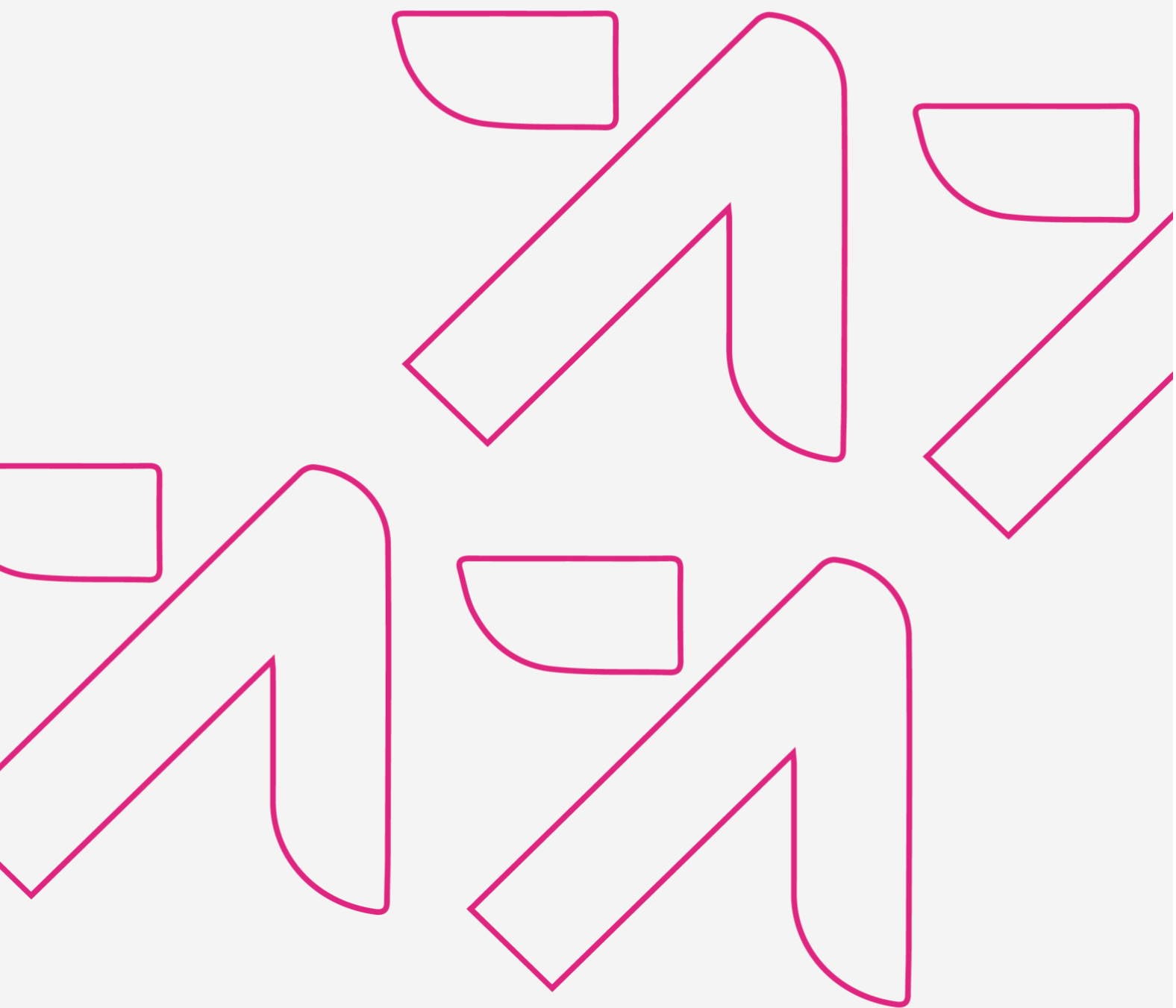




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 9. Seguimiento y mejora continua en ciberseguridad

Encaje en el curso 2026/2027: tema 9 del temario oficial, dentro del RA5 (detectar y documentar incidentes siguiendo los procedimientos establecidos). Los apartados 2 a 5 amplían lo que piden los criterios del RA5 sobre seguimiento, documentación y lecciones aprendidas.

1. Por qué no termina al cerrar

Un incidente cerrado sin revisión es un incidente que se repetirá. La fase posterior es la más barata de todas y la que más a menudo se omite, porque cuando llega todo el mundo quiere volver a su trabajo.

2. Lecciones aprendidas

2.1. La reunión posterior al incidente

- Se celebra pronto, dentro de las dos semanas siguientes al cierre, con todos los que participaron.
- **Sin culpables:** se analiza qué falló en los procesos y en los sistemas, no quién se equivocó. Si la gente teme las consecuencias, ocultará información.
- Dura lo justo y termina con acciones concretas.

2.2. Las preguntas

- ¿Qué ocurrió exactamente y en qué momentos?
- ¿Cómo se detectó? ¿Se pudo detectar antes?
- ¿Qué funcionó bien y conviene mantener?
- ¿Qué no funcionó o hizo perder tiempo?
- ¿Se siguieron los procedimientos? ¿Eran adecuados?
- ¿Qué información o herramienta se echó en falta?
- ¿Qué haríamos distinto la próxima vez?

2.3. De la lección a la acción

Una lección sin responsable ni fecha es un deseo. Cada conclusión se convierte en una acción:

Hallazgo	Acción	Responsable	Plazo
El acceso fue por una cuenta sin MFA	Activar MFA en todas las cuentas con acceso remoto	Sistemas	15 días
Se tardó dos horas en localizar al proveedor	Lista de contactos de emergencia, impresa y revisada cada trimestre	Seguridad	7 días
Nadie sabía quién podía autorizar la parada del servidor	Definir la cadena de decisión en el plan de respuesta	Dirección	30 días

3. El informe posterior al incidente

Tiene dos lectores distintos, así que conviene separar un resumen para la dirección y un detalle técnico.

1. Resumen ejecutivo: qué pasó, qué impacto tuvo y qué se va a hacer.
2. Clasificación y gravedad.
3. Línea temporal.
4. Causa raíz.
5. Alcance e impacto: sistemas, datos, tiempo de parada, coste estimado.
6. Actuaciones realizadas.
7. Notificaciones efectuadas.
8. Lecciones aprendidas y plan de acción.
9. Anexos: indicadores de compromiso y evidencias.

4. Análisis y seguimiento de incidentes

4.1. El registro de incidentes

Todos los incidentes, también los pequeños, se anotan con los mismos campos: fecha, tipo, origen, sistemas afectados, gravedad, tiempos y causa. Es lo que permite ver patrones: el mismo departamento, el mismo tipo de fallo, el mismo proveedor.

4.2. Métricas

Métrica	Qué mide
MTTD	Tiempo medio desde que empieza un incidente hasta que se detecta
MTTA	Tiempo medio hasta que alguien se hace cargo de la alerta
MTTC	Tiempo medio hasta la contención
MTTR	Tiempo medio hasta la resolución
Incidentes por tipo y por gravedad	Dónde se concentra el problema
Recurrencia	Cuántos incidentes repiten una causa ya conocida
Acciones correctivas cerradas en plazo	Si las lecciones se aplican de verdad

Ejemplo: un incidente empieza a las 02:31, se detecta a las 09:10, se contiene a las 10:05 y se resuelve a las 17:40. La detección tardó 6 h 39 min, la contención 55 min desde la

detección y la resolución 8 h 30 min desde la detección. El dato que más llama la atención es el primero: de noche nadie miraba las alertas.

4.3. Tendencias

Las métricas valen por su evolución, no por un valor aislado. Se revisan cada trimestre y se presentan a la dirección con una lectura clara: qué mejora, qué empeora y qué se propone.

5. Evaluaciones y auditorías

5.1. Simulacros

- **Ejercicio de mesa (tabletop):** el equipo se sienta y recorre un escenario sobre el papel. Barato y muy revelador sobre quién decide y a quién se llama.
- **Ejercicio técnico:** se ejecuta de verdad una parte, como restaurar una copia o aislar un equipo.
- **Simulación completa:** escenario realista con participación de toda la organización.

5.2. Pruebas de la defensa

- **Equipo rojo:** simula a un atacante real para poner a prueba detección y respuesta.
- **Equipo morado:** atacantes y defensores trabajan juntos, técnica a técnica, para mejorar las detecciones.
- Simulaciones de phishing y auditorías periódicas (tema 5).

5.3. Qué se evalúa

No solo si la tecnología detecta, sino si las personas saben qué hacer, si los contactos están al día y si los procedimientos son utilizables bajo presión.

6. Actualización y mejora de protocolos

Los procedimientos se revisan:

- Después de cada incidente relevante o simulacro.
- Cuando cambian los sistemas, la organización o los proveedores.
- Cuando cambia la normativa.
- Cuando aparecen técnicas de ataque nuevas.
- Como mínimo, una vez al año.

Cada documento lleva versión, fecha y responsable. Un procedimiento que cita a una persona que ya no trabaja en la empresa indica que nadie lo ha abierto en mucho tiempo.

7. Protocolos de concienciación por departamento

Lo aprendido en los incidentes vuelve a las personas en forma de protocolos actualizados. Amplían los del tema 2.

7.1. Recepción y atención telefónica

- No confirmar ni facilitar datos de empleados, horarios o proveedores a desconocidos.
- Ante una petición inusual: tomar nota y devolver la llamada tras verificar.
- Las visitas se registran y van siempre acompañadas.

7.2. Administración

- Fraude del CEO y cambio de cuenta de proveedor: verificación por un segundo canal, siempre.
- Doble firma en pagos y en altas de proveedores.
- La urgencia y el secreto son señales de alarma, no motivos para saltarse el procedimiento.

7.3. Recursos humanos

- Ofertas de empleo y currículos como vía de entrada de malware.
- Peticiones de cambio de cuenta de nómina: verificar con el empleado en persona o por un canal conocido.
- Aviso inmediato a sistemas de las bajas de personal.

7.4. Directivos

- Su información pública (cargos, agenda, redes sociales) alimenta los ataques dirigidos.
- Sin excepciones a MFA ni a los procedimientos de pago.
- Precaución especial en viajes y con dispositivos personales.

8. Base de conocimiento

Con el tiempo, el registro, los informes y los procedimientos forman la memoria de la organización: cómo se resolvió un caso parecido, qué indicadores se vieron, qué proveedor respondió bien. Mantenerla ordenada y accesible ahorra horas en el siguiente incidente.

Para ampliar

- NIST SP 800-61: apartado de actividad posterior al incidente.
- NIST SP 800-84: guía de ejercicios y pruebas de planes.

- INCIBE-CERT: ejercicios y juegos de rol de respuesta a incidentes para empresas.
- ISO/IEC 27035: aprendizaje a partir de los incidentes.